

**NexusTrace**

INFORME DE PENTESTING

Evaluación de Seguridad - Servidor Web Debian

Cliente	4Geeks Academy
Proveedor del servicio	NexusTrace S.A.S
Analista responsable	Jose Muñoz A.
Tipo de evaluación	Pentesting - Caja Gris
Sistema objetivo	Servidor Debian - IP 192.168.64.9
Fecha	Marzo 2026
Autorización	Evaluación realizada bajo autorización del cliente
Clasificación	CONFIDENCIAL

Proyecto Final — Bootcamp de Ciberseguridad — 4Geeks Academy

TABLA DE CONTENIDO

1. Resumen Ejecutivo.....	3
2. Entorno y Alcance.....	4
3. Metodología.....	4
4. Reconocimiento - Fase 1.....	5
5. Reconocimiento - Fase 2 (Análisis Profundo).....	10
6. Vulnerabilidades identificadas.....	13
7. Validación Post-hardening.....	25
8. Recomendaciones.....	26
9. Conclusión.....	26

1. Resumen Ejecutivo

NexusTrace S.A.S. realizó una evaluación de seguridad ofensiva (pentesting de caja gris) sobre el servidor web administrado por 4Geeks Academy en marzo de 2026. El objetivo fue identificar vulnerabilidades activas, verificar su explotabilidad y aplicar las medidas correctivas correspondientes.

Se identificaron siete vulnerabilidades en dos ciclos de análisis: seis en el reconocimiento inicial (Fase 1) y una adicional identificada en el análisis profundo con herramientas especializadas (Fase 2). Tres presentaban severidad ALTA y cuatro severidad MEDIA. Todas fueron corregidas y verificadas. Al cierre del informe el servidor opera con superficie de ataque significativamente reducida.

ID	Vulnerabilidad	Severidad	Estado
VUL-001	Credenciales débiles en MariaDB	ALTA	✓ Corregida
VUL-002	Autenticación SSH insegura	ALTA	✓ Corregida
VUL-003	Permisos inseguros en wp-config.php	ALTA	✓ Corregida
VUL-004	Acceso FTP anónimo habilitado	MEDIA	✓ Corregida
VUL-005	Information Disclosure — Apache	MEDIA	✓ Corregida
VUL-006	Directorio web listable	MEDIA	✓ Corregida
VUL-007	XML-RPC habilitado — Brute Force / DLP	MEDIA	✓ Corregida

Escala de severidad: ALTA — Compromiso directo del sistema o datos. MEDIA — Amplía la superficie de ataque. BAJA — Riesgo menor, buenas prácticas.

2. Entorno y Alcance

Componente	Descripción
Sistema objetivo	Servidor Debian - IP 192.168.64.9
Virtualización	Red Bridge (Apple Silicon arm64)
Servicios evaluados	Apache HTTP, WordPress, MariaDB, SSH (22), FTP vsftpd (21)
Modalidad	Caja Gris — acceso parcial al sistema objetivo
Máquina analista	IP 192.168.64.7
Fuera de alcance	Otros hosts de la red (192.168.64.x), bases externas, y cualquier IP distinta a 192.168.64.9

Componente		Descripción	
Período		Marzo 2026	

3. Metodología

La evaluación siguió las fases del PTES (Penetration Testing Execution Standard). Para la parte web se tomaron como referencia las pruebas de la OWASP Testing Guide (OTG-CONFIG). La evaluación se realizó en dos ciclos: reconocimiento inicial (Fase 1) y análisis profundo con herramientas especializadas (Fase 2).

Fases

Fase	Actividad	Descripción
1	Reconocimiento externo	Escaneo de servicios y puertos - Nmap
2	Enumeración web	Rutas web expuestas, cabeceras HTTP y recursos accesibles
3	Análisis profundo	Escaneo de CVEs (nmap --script vuln), nikto, wpscan
4	Identificación de vulnerabilidades	Análisis de configuración, credenciales y permisos
5	Explotación controlada	Verificación real en entorno autorizado
6	Medidas correctivas	Hardening y verificación post-hardening
7	Reporting	Documentación de hallazgos, evidencias y recomendaciones

Herramientas utilizadas

Herramienta	Tipo	Uso
nmap	Scanner	Escaneo de puertos y servicios
gobuster	Fuzzer	Enumeración de directorios y archivos web
curl	HTTP client	Inspección de cabeceras HTTP y explotación web
wpscan	WP Scanner	Auditoría WordPress: usuarios, plugins, configuración
ss / iproute2	Network	Puertos en escucha internos

Herramienta	Tipo	Uso
ps aux	System	Procesos activos del servidor
mysql client	DB Client	Verificación de acceso a MariaDB
ssh-keygen	OpenSSH	Generación de claves RSA 4096 bits
nikto	Web Scanner	Análisis de vulnerabilidades web
nmap --script vuln	NSE	Escaneo de CVEs conocidos

4. Reconocimiento - Fase 1

Se realizó un análisis inicial del sistema objetivo desde la máquina analista para identificar los servicios expuestos, sus versiones y la superficie de ataque disponible.

4.1 Escaneo de puertos - Nmap

Escaneo inicial desde la máquina analista (192.168.64.7):

```
nmap -sV -Pn 192.168.64.9
```

```
operador@debian-analista:~$ nmap -sV -Pn 192.168.64.9
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-09 17:52 -05
Nmap scan report for 192.168.64.9
Host is up (0.0012s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.20 seconds
```

Resultado del escaneo Nmap inicial

Puerto	Estado	Servicio	Versión
21/tcp	open	ftp	vsftpd 3.0.3
22/tcp	open	ssh	OpenSSH 9.2p1
80/tcp	open	http	Apache 2.4.62

4.2 Análisis de procesos y puertos internos

En modalidad caja gris, se verificó el estado interno del servidor:

```
ps aux
```

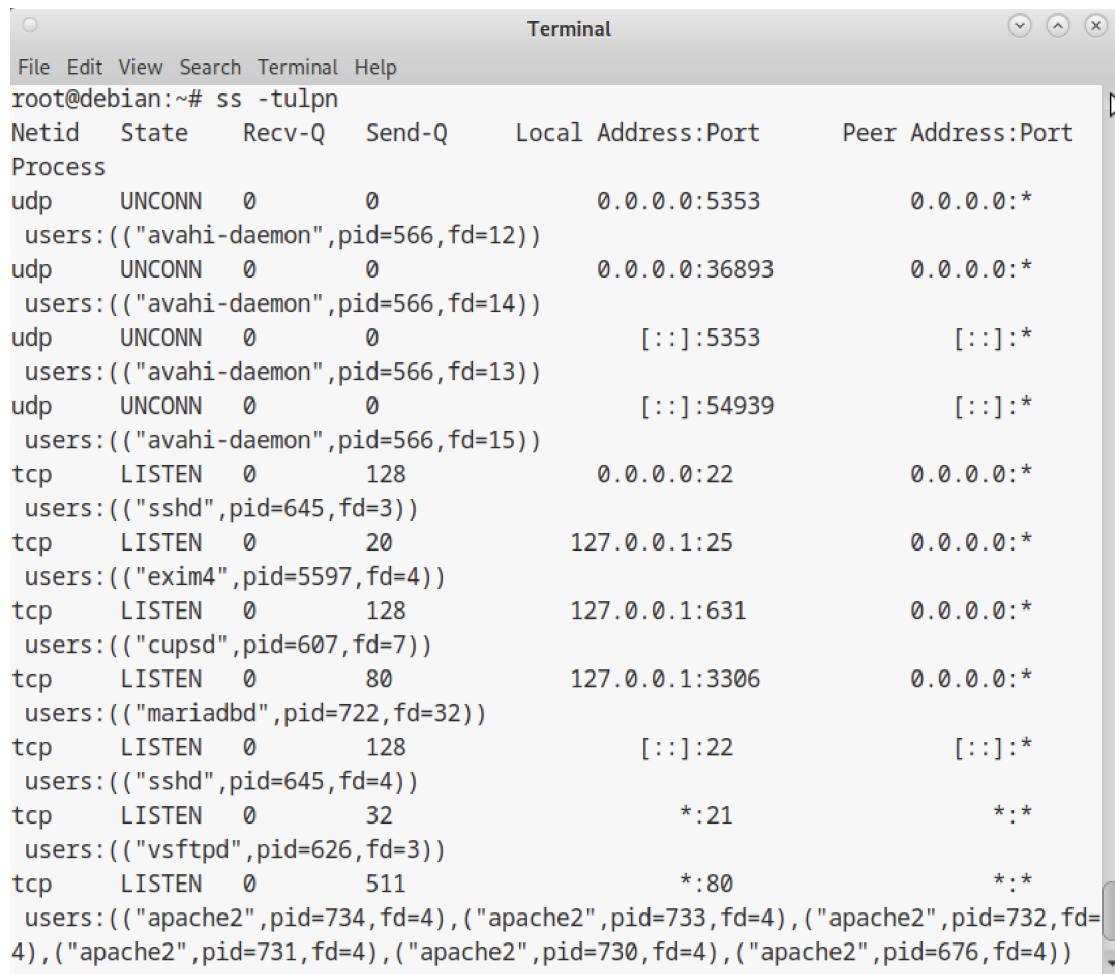
```
root@debian:~# ps aux
USER          PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root           1  0.8  0.3 169140 13736 ?        S    19:13   0:23 /sbin/init
root           2  0.0  0.0      0     0 ?        S    19:13   0:00 [kthreadd]
root           3  0.0  0.0      0     0 ?        I<   19:13   0:00 [rcu_gp]
root           4  0.0  0.0      0     0 ?        I<   19:13   0:00 [rcu_par_gp]
root           5  0.0  0.0      0     0 ?        I<   19:13   0:00 [slub_flushwq]
root           6  0.0  0.0      0     0 ?        I<   19:13   0:00 [netns]
root           8  0.0  0.0      0     0 ?        I<   19:13   0:00 [kworker/0:0H]
root          10  0.0  0.0      0     0 ?        I<   19:13   0:00 [mm_percpu_wq]
root          11  0.0  0.0      0     0 ?        I    19:13   0:00 [rcu_tasks_kt]
root          12  0.0  0.0      0     0 ?        I    19:13   0:00 [rcu_tasks_ru]
root          13  0.0  0.0      0     0 ?        I    19:13   0:00 [rcu_tasks_tr]
root          14  0.0  0.0      0     0 ?        S    19:13   0:01 [ksoftirqd/0]
root          15  0.5  0.0      0     0 ?        I    19:13   0:15 [rcu_preempt]
root          16  0.0  0.0      0     0 ?        S    19:13   0:00 [migration/0]
root          18  0.0  0.0      0     0 ?        S    19:13   0:00 [cpuhp/0]
root          19  0.0  0.0      0     0 ?        S    19:13   0:00 [cpuhp/1]
root          20  0.0  0.0      0     0 ?        S    19:13   0:00 [migration/1]
root          21  0.0  0.0      0     0 ?        S    19:13   0:01 [ksoftirqd/1]
root          23  0.0  0.0      0     0 ?        I<   19:13   0:00 [kworker/1:0H]
root          24  0.0  0.0      0     0 ?        S    19:13   0:00 [cpuhp/2]
root          25  0.0  0.0      0     0 ?        S    19:13   0:00 [migration/2]
```

Procesos activos del servidor

Terminal										
File	Edit	View	Search	Terminal	Help					
root	1276	0.0	0.0	7196	3820	pts/0	Ss	03:32	0:00	bash
root	1283	0.0	0.1	233748	7500	?	Ssl	03:32	0:00	/usr/libexec/
Debian-+	5597	0.0	0.4	28636	16216	?	Ss	03:35	0:25	/usr/sbin/exi
root	181986	0.0	0.0	0	0	?	I	04:37	0:11	[kworker/1:2-
root	201549	0.0	0.4	33084	17248	?	Ss	04:58	0:03	/lib/systemd/
root	211335	0.0	0.1	16552	6176	?	Ss	05:05	0:00	/sbin/wpa_sup
systemd+	211422	0.0	0.1	90128	6924	?	Ssl	05:05	0:01	/lib/systemd/
root	211520	0.0	0.1	27436	6344	?	Ss	05:05	0:01	/lib/systemd/
root	242746	0.0	0.5	258544	21960	?	Ssl	05:11	0:05	/usr/sbin/Net
mysql	243054	0.0	3.6	1745260	144896	?	Ssl	05:12	0:22	/usr/sbin/mar
avahi	246060	0.0	0.0	8380	3976	?	Ss	05:12	0:05	avahi-daemon:
avahi	246062	0.0	0.0	8112	364	?	S	05:12	0:00	avahi-daemon:
root	246130	0.0	0.3	394724	14540	?	Ssl	05:12	0:00	/usr/libexec/
root	250040	0.0	0.2	15452	9484	?	Ss	05:17	0:00	sshd: /usr/sb
root	250272	0.0	0.9	268708	36216	?	Ss	05:17	0:06	/usr/sbin/apa
root	301273	0.0	0.0	0	0	?	I	06:05	0:10	[kworker/2:0-
root	308831	0.0	0.1	10212	4288	?	Ss	06:16	0:00	/usr/sbin/vsf
root	392914	0.0	0.0	0	0	?	I	08:13	0:08	[kworker/3:0-
www-data	392990	0.0	0.4	269296	16212	?	S	08:13	0:00	/usr/sbin/apa
www-data	392991	0.0	0.4	269296	16212	?	S	08:13	0:00	/usr/sbin/apa
www-data	392992	0.0	0.4	269296	16212	?	S	08:13	0:00	/usr/sbin/apa
www-data	392993	0.0	0.4	269296	16200	?	S	08:13	0:00	/usr/sbin/apa
www-data	392994	0.0	0.4	269296	16208	?	S	08:13	0:00	/usr/sbin/apa
root	393000	0.0	0.2	27068	9440	?	Ss	08:13	0:00	/usr/sbin/cup
root	393003	0.0	0.3	176140	13344	?	Ssl	08:13	0:00	/usr/sbin/cup
root	399330	0.0	0.0	0	0	?	I	08:22	0:14	[kworker/0:0-

Detalle de procesos del sistema

ss -tulpn



```

root@debian:~# ss -tulpn
Netid  State  Recv-Q  Send-Q  Local Address:Port  Peer Address:Port
Process
udp    UNCONN  0        0        0.0.0.0:5353        0.0.0.0:*
users: (("avahi-daemon",pid=566,fd=12))
udp    UNCONN  0        0        0.0.0.0:36893       0.0.0.0:*
users: (("avahi-daemon",pid=566,fd=14))
udp    UNCONN  0        0        [::]:5353          [::]:*
users: (("avahi-daemon",pid=566,fd=13))
udp    UNCONN  0        0        [::]:54939         [::]:*
users: (("avahi-daemon",pid=566,fd=15))
tcp    LISTEN  0        128      0.0.0.0:22         0.0.0.0:*
users: (("sshd",pid=645,fd=3))
tcp    LISTEN  0        20       127.0.0.1:25       0.0.0.0:*
users: (("exim4",pid=5597,fd=4))
tcp    LISTEN  0        128      127.0.0.1:631      0.0.0.0:*
users: (("cupsd",pid=607,fd=7))
tcp    LISTEN  0        80       127.0.0.1:3306     0.0.0.0:*
users: (("mariadb",pid=722,fd=32))
tcp    LISTEN  0        128      [::]:22           [::]:*
users: (("sshd",pid=645,fd=4))
tcp    LISTEN  0        32       *:21              *: *
users: (("vsftpd",pid=626,fd=3))
tcp    LISTEN  0        511      *:80              *: *
users: (("apache2",pid=734,fd=4), ("apache2",pid=733,fd=4), ("apache2",pid=732,fd=4), ("apache2",pid=731,fd=4), ("apache2",pid=730,fd=4), ("apache2",pid=676,fd=4))

```

Puertos en escucha internos

4.3 Enumeración web

Enumeración de directorios y verificación de recursos expuestos:

```
gobuster dir -u http://192.168.64.9 -w /tmp/common.txt
```



```

operator@debian-analista: ~
/0 (Status: 301) [Size: 0] [--> http://192.168.64.9/0/]
/admin (Status: 302) [Size: 0] [--> http://localhost/wp-admin/]
/dashboard (Status: 302) [Size: 0] [--> http://localhost/wp-admin/]
/favicon.ico (Status: 302) [Size: 0] [--> http://localhost/wp-includes/
images/w-logo-blue-white-bg.png]
/index.php (Status: 301) [Size: 0] [--> http://192.168.64.9/]
/login (Status: 302) [Size: 0] [--> http://localhost/wp-login.php
]
/render/https://www.google.com (Status: 301) [Size: 0] [--> http://192.168.64.9/
render/https://www.google.com]
/robots.txt (Status: 200) [Size: 109]
/server-status (Status: 403) [Size: 317]
/wp-admin (Status: 301) [Size: 355] [--> http://192.168.64.9/wp-admin/]
/wp-content (Status: 301) [Size: 357] [--> http://192.168.64.9/wp-content/]
/wp-includes (Status: 301) [Size: 358] [--> http://192.168.64.9/wp-includes/]
/xmlrpc.php (Status: 405) [Size: 42]
Progress: 4751 / 4751 (100.00%)
=====
Finished
=====
operator@debian-analista:~$

```

Enumeración de directorios con Gobuster

```
curl http://192.168.64.9/robots.txt
```

```
curl -I http://192.168.64.9/wp-login.php
```

```

operator@debian-analista: ~
nmap done: 1 IP address (1 host up) scanned in 16.19 seconds
operator@debian-analista:~$ curl -I http://192.168.64.9
HTTP/1.1 200 OK
Date: Tue, 10 Mar 2026 02:08:48 GMT
Server: Apache/2.4.66 (Debian)
Last-Modified: Mon, 30 Sep 2024 14:44:22 GMT
ETag: "29cd-623573d915b52"
Accept-Ranges: bytes
Content-Length: 10701
Vary: Accept-Encoding
Content-Type: text/html

operator@debian-analista:~$ curl http://192.168.64.9/robots.txt
User-agent: *
Disallow: /wp-admin/
Allow: /wp-admin/admin-ajax.php

Sitemap: http://localhost/wp-sitemap.xml
operator@debian-analista:~$ curl -I http://192.168.64.9/wp-admin
HTTP/1.1 301 Moved Permanently
Date: Tue, 10 Mar 2026 02:12:20 GMT
Server: Apache/2.4.66 (Debian)
Location: http://192.168.64.9/wp-admin/
Content-Type: text/html; charset=iso-8859-1

```

Verificación de robots.txt y panel wp-login

5. Reconocimiento - Fase 2 (Análisis Profundo)

En la segunda fase se utilizaron herramientas especializadas para identificar vulnerabilidades conocidas (CVEs), analizar la configuración web y auditar WordPress. Este análisis identificó la vulnerabilidad VUL-007.

5.1 Escaneo de CVEs - nmap --script vuln

```
nmap --script vuln -Pn 192.168.64.9
```

```
operador@debian-analista:~$ nmap -sV --script vuln 192.168.64.9
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 01:32 -05
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_  Hosts are all up (not vulnerable).
Nmap scan report for 192.168.64.9
Host is up (0.0015s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
| vulners:
|   cpe:/a:openbsd:openssh:9.2p1:
|     PACKETSTORM:179290      10.0      https://vulners.com/packetstorm/PACKETSTORM:179290      *EXPLOIT*
|     1EEC8894-D2F7-547C-827C-915BE866875C      10.0      https://vulners.com/githubexploit/1EEC8894-D2F7-547C-827C-915BE866875C      *EXPLOIT*
|     PACKETSTORM:173661      9.8       https://vulners.com/packetstorm/PACKETSTORM:173661      *EXPLOIT*
|     F0979183-AE88-53B4-86CF-3AF0523F3807      9.8       https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807      *EXPLOIT*
|     CVE-2023-38408      9.8       https://vulners.com/cve/CVE-2023-38408
```

Escaneo de vulnerabilidades NSE - parte 1

```
ubexploit/DA18D761-BB81-54B6-85CB-CFD73CE33621      *EXPLOIT*
|   D8974199-6B08-5895-9610-919F71468F23      8.1      https://vulners.com/githubexploit/D8974199-6B08-5895-9610-919F71468F23      *EXPLOIT*
|   D52370EF-02EE-507D-9212-2D8EA86CBA94      8.1      https://vulners.com/githubexploit/D52370EF-02EE-507D-9212-2D8EA86CBA94      *EXPLOIT*
|   CVE-2024-6387      8.1      https://vulners.com/cve/CVE-2024-6387
|   CFEBF7AF-651A-5302-80B8-F8146D5B33A6      8.1      https://vulners.com/githubexploit/CFEBF7AF-651A-5302-80B8-F8146D5B33A6      *EXPLOIT*
|   C6FB6D50-F71D-5870-B671-D6A09A95627F      8.1      https://vulners.com/githubexploit/C6FB6D50-F71D-5870-B671-D6A09A95627F      *EXPLOIT*
|   C623D558-C162-5D17-88A5-4799A2BEC001      8.1      https://vulners.com/githubexploit/C623D558-C162-5D17-88A5-4799A2BEC001      *EXPLOIT*
|   C5B2D4A1-8C3B-5FF7-B620-EDE207B027A0      8.1      https://vulners.com/githubexploit/C5B2D4A1-8C3B-5FF7-B620-EDE207B027A0      *EXPLOIT*
|   C185263E-3E67-5550-B9C0-AB9C15351960      8.1      https://vulners.com/githubexploit/C185263E-3E67-5550-B9C0-AB9C15351960      *EXPLOIT*
|   BDA609DA-6936-50DC-A325-19FE2CC68562      8.1      https://vulners.com/githubexploit/BDA609DA-6936-50DC-A325-19FE2CC68562      *EXPLOIT*
|   BA3887BD-F579-53B1-A4A4-FF49E953E1C0      8.1      https://vulners.com/githubexploit/BA3887BD-F579-53B1-A4A4-FF49E953E1C0      *EXPLOIT*
|   B1F444E0-F217-5FC0-B266-EBD48589940F      8.1      https://vulners.com/githubexploit/B1F444E0-F217-5FC0-B266-EBD48589940F      *EXPLOIT*
|   92254168-3B26-54C9-B9BE-B4B7563586B5      8.1      https://vulners.com/githubexploit/92254168-3B26-54C9-B9BE-B4B7563586B5      *EXPLOIT*
```

Escaneo de vulnerabilidades NSE - parte 2

```

ubexploit/1EEC8894-D2F7-547C-827C-915BE866875C *EXPLOIT*
| PACKETSTORM:173661 9.8 https://vulners.com/packetstorm/PACKETSTORM:173661 *EXPLOIT*
| F0979183-AE88-53B4-86CF-3AF0523F3807 9.8 https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807 *EXPLOIT*
| CVE-2023-38408 9.8 https://vulners.com/cve/CVE-2023-38408
| CVE-2023-28531 9.8 https://vulners.com/cve/CVE-2023-28531
| B8190CDB-3EB9-5631-9828-8064A1575B23 9.8 https://vulners.com/githubexploit/B8190CDB-3EB9-5631-9828-8064A1575B23 *EXPLOIT*
| 8FC9C5AB-3968-5F3C-825E-E8DB5379A623 9.8 https://vulners.com/githubexploit/8FC9C5AB-3968-5F3C-825E-E8DB5379A623 *EXPLOIT*
| 8AD01159-548E-546E-AA87-2DE89F3927EC 9.8 https://vulners.com/githubexploit/8AD01159-548E-546E-AA87-2DE89F3927EC *EXPLOIT*
| 6192C35D-F78B-5C0A-AB8D-9826A79A5320 9.8 https://vulners.com/githubexploit/6192C35D-F78B-5C0A-AB8D-9826A79A5320 *EXPLOIT*
| 33D623F7-98E0-5F75-80FA-81AA666D1340 9.8 https://vulners.com/githubexploit/33D623F7-98E0-5F75-80FA-81AA666D1340 *EXPLOIT*
| 2227729D-6700-5C8F-8930-1EEAFD4B9FF0 9.8 https://vulners.com/githubexploit/2227729D-6700-5C8F-8930-1EEAFD4B9FF0 *EXPLOIT*
| 0221525F-07F5-5790-912D-F4B9E2D1B587 9.8 https://vulners.com/githubexploit/0221525F-07F5-5790-912D-F4B9E2D1B587 *EXPLOIT*
| F8981437-1287-5B69-93F1-657DFB1DCE59 9.3 https://vulners.com/githubexploit/F8981437-1287-5B69-93F1-657DFB1DCE59 *EXPLOIT*
| CB2926E1-2355-5C82-A42A-D4F72F114F9B 9.3 https://vulners.com/githubexploit/CB2926E1-2355-5C82-A42A-D4F72F114F9B *EXPLOIT*

```

Escaneo de vulnerabilidades NSE - parte 3

CVE	Descripción	Impacto
CVE-2023-38408	ssh-agent PKCS#11 RCE — Ejecución remota de código mediante agente SSH	ALTO
CVE-2023-51767	Regression Attack — Login no autenticado como root en OpenSSH 9.2p1	ALTO

5.2 Análisis web - nikto

```

perl nikto.pl -h http://192.168.64.9
operador@debian-analista:~/nikto/program$ perl nikto.pl -h http://192.168.64.9
- Nikto v2.6.0
-----
+ Target IP: 192.168.64.9
+ Target Hostname: 192.168.64.9
+ Target Port: 80
+ Platform: Windows
+ Start Time: 2026-03-11 01:49:16 (GMT-5)
-----
+ Server: Apache
+ [000427] /: Link header(s) found with value(s): <http://localhost/index.php/wp-json/>; rel="https://api.w.org/". See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Link
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /wp-admin/: Uncommon header(s) 'x-redirect-by' found, with contents: WordPress.
+ [999996] /robots.txt: contains 2 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security

```

Resultado del análisis Nikto

Hallazgo	Descripción / Impacto
Headers de seguridad faltantes	CSP, Referrer-Policy, HSTS, X-Content-Type-Options ausentes
/wp-login.php	Panel administrador accesible sin protección adicional
Server: Apache/2.4.62	Versión del servidor expuesta en cabeceras HTTP
x-redirect-by	Cabecera inusual — indica WordPress instalado

5.3 Análisis WordPress - wpscan

```
wpscan --url http://192.168.64.9 --enumerate u
```

```
[+] XML-RPC seems to be enabled: http://192.168.64.9/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
```

Resultado de WPScan

6. Vulnerabilidades identificadas

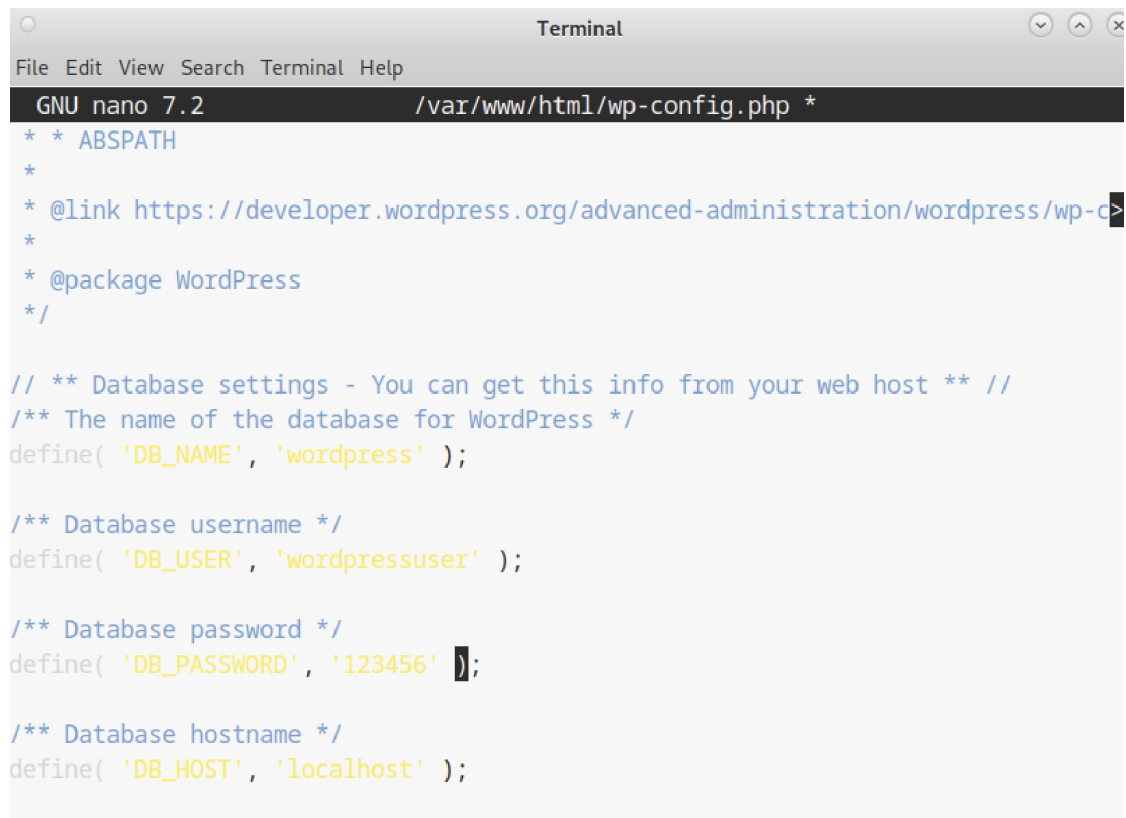
A continuación se documenta cada vulnerabilidad con descripción, evidencia de explotación y corrección aplicada.

VUL-001 - Credenciales débiles en MariaDB

Campo	Detalle
Descripción	El usuario wordpressuser en MariaDB utilizaba la contraseña 123456, trivialmente adivinable
Severidad	ALTA
Impacto	Acceso completo a la base de datos: extracción de datos, emails y contraseñas
Evidencia	wp-config.php — DB_USER: wordpressuser / DB_PASSWORD: 123456 en texto plano

Corrección aplicada:

```
ALTER USER 'wordpressuser'@'localhost' IDENTIFIED BY 'SegurA_2026';
```



```
GNU nano 7.2 /var/www/html/wp-config.php *
* * ABSPATH
*
* @link https://developer.wordpress.org/advanced-administration/wordpress/wp-c
*
* @package WordPress
*/

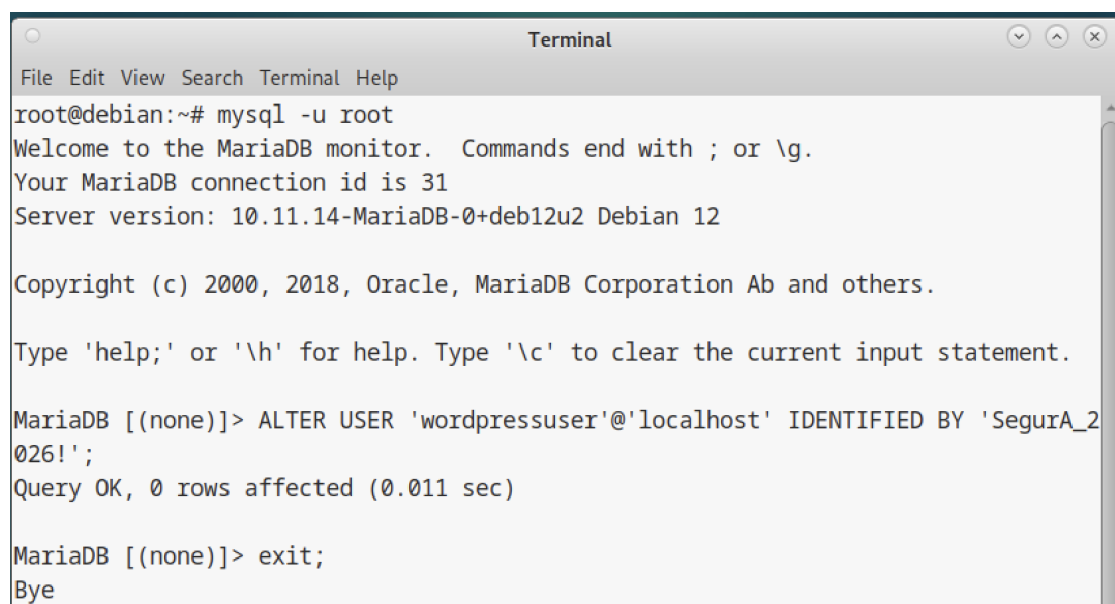
// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** Database username */
define( 'DB_USER', 'wordpressuser' );

/** Database password */
define( 'DB_PASSWORD', '123456' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );
```

Cambio de contraseña en MariaDB



```
root@debian:~# mysql -u root
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 10.11.14-MariaDB-0+deb12u2 Debian 12

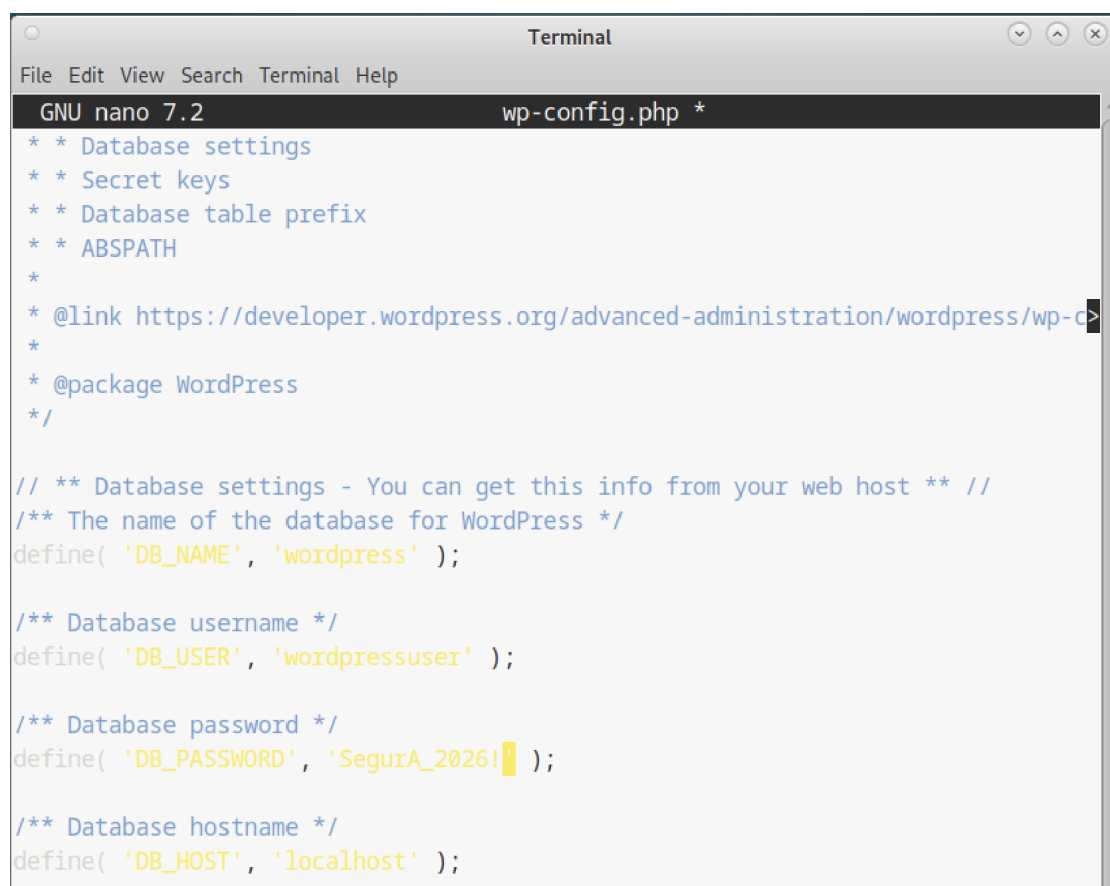
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> ALTER USER 'wordpressuser'@'localhost' IDENTIFIED BY 'Segura_2026!';
Query OK, 0 rows affected (0.011 sec)

MariaDB [(none)]> exit;
Bye
```

Verificación de credenciales antiguas rechazadas



```
GNU nano 7.2 wp-config.php *
* * Database settings
* * Secret keys
* * Database table prefix
* * ABSPATH
*
* @link https://developer.wordpress.org/advanced-administration/wordpress/wp-c
*
* @package WordPress
*/

// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** Database username */
define( 'DB_USER', 'wordpressuser' );

/** Database password */
define( 'DB_PASSWORD', 'SegurA_2026!' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );
```

Validación de acceso con nueva contraseña

```
root@debian:~# mysql -u wordpress -p'passwordantigua' wordpress
ERROR 1698 (28000): Access denied for user 'wordpress'@'localhost'
```

Confirmación: ERROR 1698 con credencial antigua

Estado: ✓ Corregida — ERROR 1698 con credencial antigua confirmado

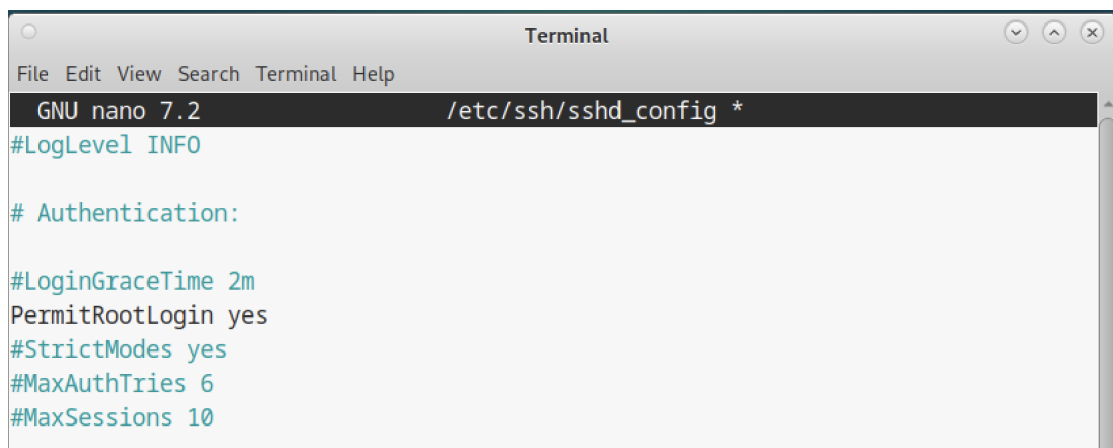
VUL-002 - Autenticación SSH insegura

Campo	Detalle
Descripción	SSH tenía PermitRootLogin yes y PasswordAuthentication yes, permitiendo autenticación por contraseña
Severidad	ALTA
Impacto	Control total remoto como root: backdoors, acceso a todos los archivos y pivoting
Evidencia	El análisis forense confirma que esta vulnerabilidad fue previamente explotada

Corrección aplicada:

```
PermitRootLogin no
PasswordAuthentication no
```

```
systemctl restart ssh
```



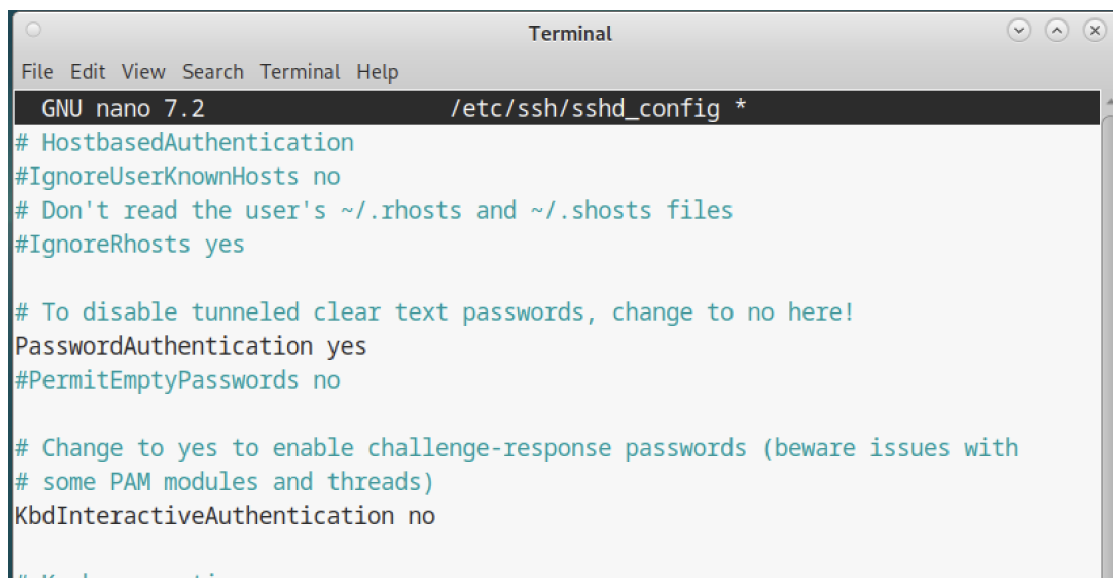
A terminal window titled 'Terminal' with a menu bar (File, Edit, View, Search, Terminal, Help). The title bar shows 'GNU nano 7.2' and the file path '/etc/ssh/sshd_config *'. The content of the file is as follows:

```
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin yes
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10
```

Configuración corregida en sshd_config



A terminal window titled 'Terminal' with a menu bar (File, Edit, View, Search, Terminal, Help). The title bar shows 'GNU nano 7.2' and the file path '/etc/ssh/sshd_config *'. The content of the file is as follows:

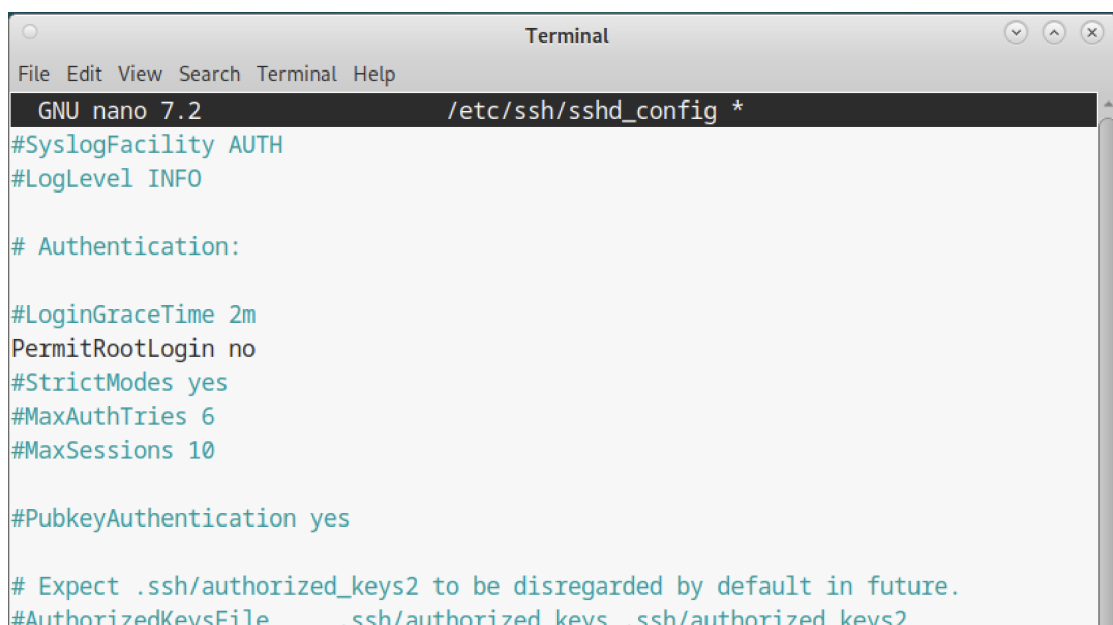
```
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication yes
#PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
KbdInteractiveAuthentication no

# Keyboard options
```

Reinicio del servicio SSH



A terminal window titled 'Terminal' with a menu bar (File, Edit, View, Search, Terminal, Help). The title bar shows 'GNU nano 7.2' and the file path '/etc/ssh/sshd_config *'. The content of the file is as follows:

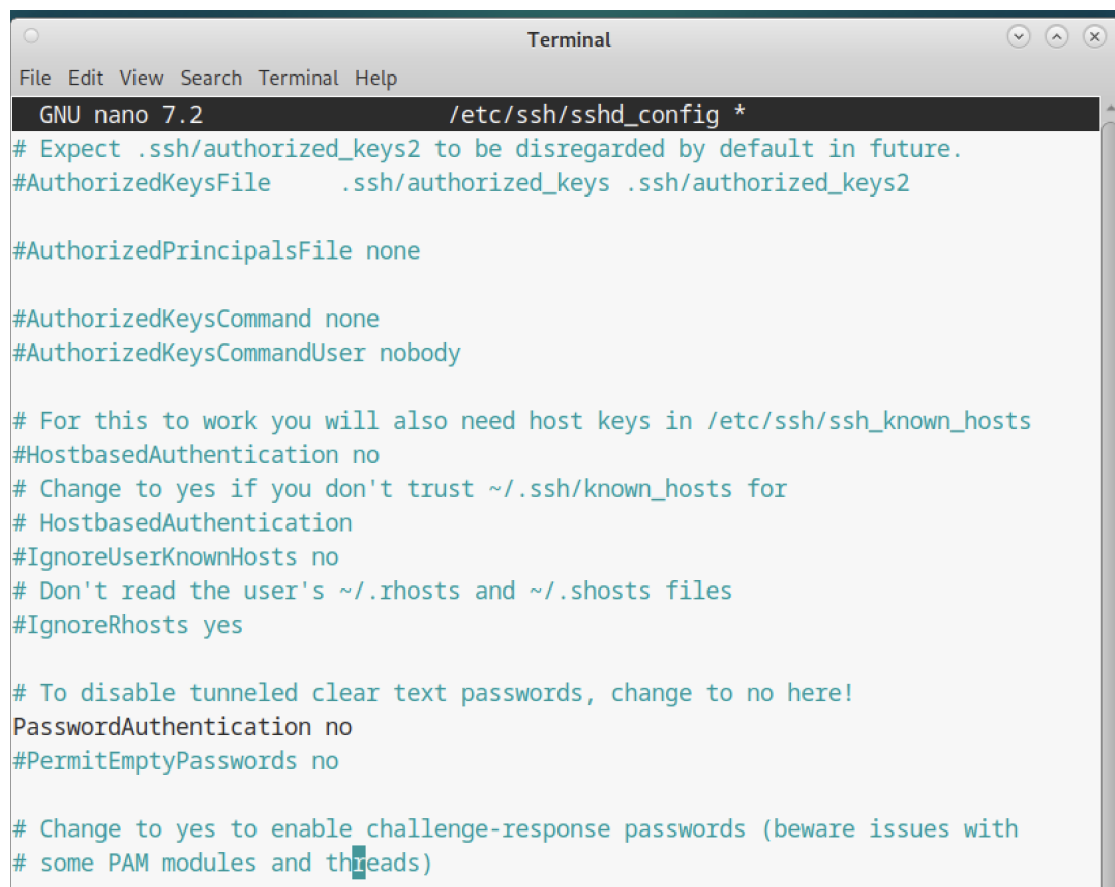
```
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized keys .ssh/authorized keys2
```


Generación de par de claves RSA 4096 bits

```
Terminal
File Edit View Search Terminal Help
GNU nano 7.2 /etc/ssh/sshd_config *
# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2

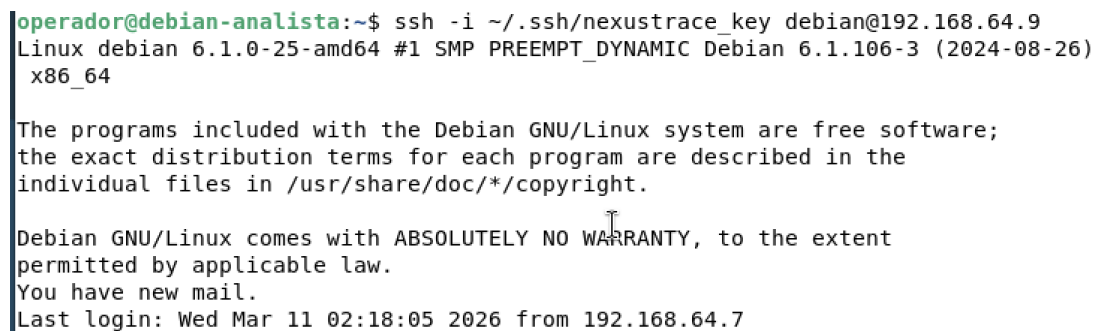
#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication no
#PermitEmptyPasswords no

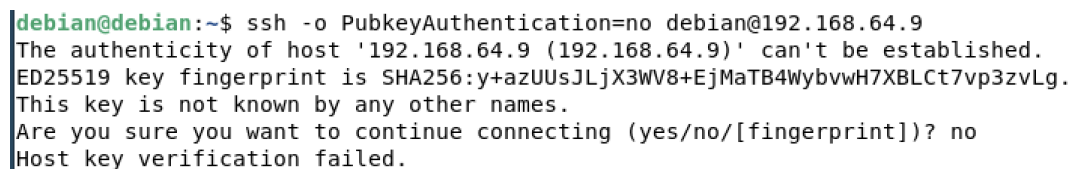
# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
```

Configuración de clave pública en authorized_keys

```
operador@debian-analista:~$ ssh -i ~/.ssh/nexustrace_key debian@192.168.64.9
Linux debian 6.1.0-25-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.106-3 (2024-08-26)
x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
You have new mail.
Last login: Wed Mar 11 02:18:05 2026 from 192.168.64.7
```

Prueba de conexión SSH con clave pública

```
debian@debian:~$ ssh -o PubkeyAuthentication=no debian@192.168.64.9
The authenticity of host '192.168.64.9 (192.168.64.9)' can't be established.
ED25519 key fingerprint is SHA256:y+azUUsJLjX3WV8+EjMaTB4WybvW7XBLCT7vp3zvLg.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? no
Host key verification failed.
```

Confirmación: Permission denied al intentar login por contraseña

Estado: ✓ Corregida — Permission denied (publickey) al intentar login por contraseña

VUL-003 - Permisos inseguros en wp-config.php

Campo	Detalle
Descripción	wp-config.php tenía permisos 777, permitiendo lectura y escritura a cualquier usuario
Severidad	ALTA
Impacto	Exposición de credenciales y claves de autenticación de WordPress
Evidencia	-rwxrwxrwx 1 www-data www-data 3823 Mar 9 21:18 wp-config.php

Corrección aplicada:

```
chmod 600 /var/www/html/wp-config.php
```

```
root@debian:~# cd /var/www/html
root@debian:/var/www/html# ls
index.html      wp-blog-header.php  wp-includes      wp-signup.php
index.php       wp-comments-post.php wp-links-opml.php wp-trackback.php
license.txt     wp-config.php       wp-load.php      xmlrpc.php
readme.html    wp-config-sample.php wp-login.php
wp-activate.php wp-content          wp-mail.php
wp-admin        wp-cron.php         wp-settings.php
root@debian:/var/www/html# nano wp-config.php
root@debian:/var/www/html# ls -l wp-config.php
-rwxrwxrwx 1 www-data www-data 3023 Mar  9 21:18 wp-config.php
root@debian:/var/www/html# chmod 600 wp-config.php
root@debian:/var/www/html# ls -l wp-config.php
-rw----- 1 www-data www-data 3023 Mar  9 21:18 wp-config.php
root@debian:/var/www/html#
```

Permisos corregidos a 600 en wp-config.php

Estado: ✓ Corregida — ls -la confirma -rw----- (chmod 600)

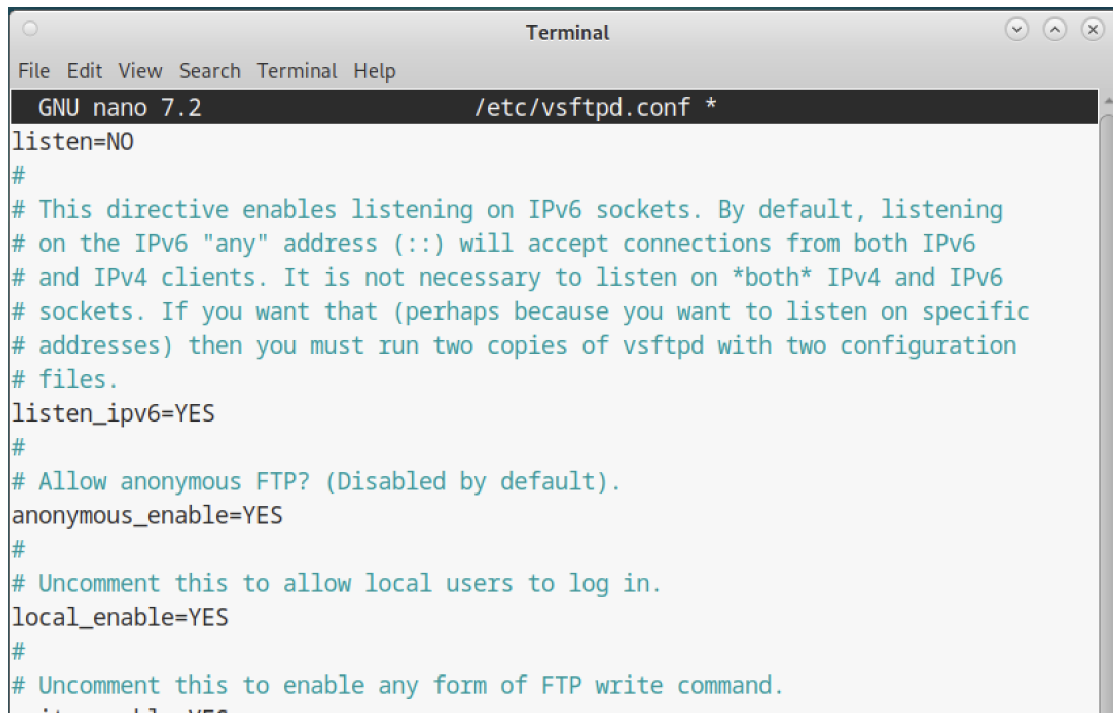
VUL-004 - Acceso FTP anónimo habilitado

Campo	Detalle
Descripción	vsftpd tenía anonymous_enable=YES y write_enable=YES, conexiones sin autenticación
Severidad	MEDIA
Impacto	Acceso no autenticado. Si FTP comparte ruta con web root, escalada a RCE
Evidencia	Puerto 21 abierto con vsftpd 3.0.3

Corrección aplicada:

```
anonymous_enable=NO
systemctl restart vsftpd
```

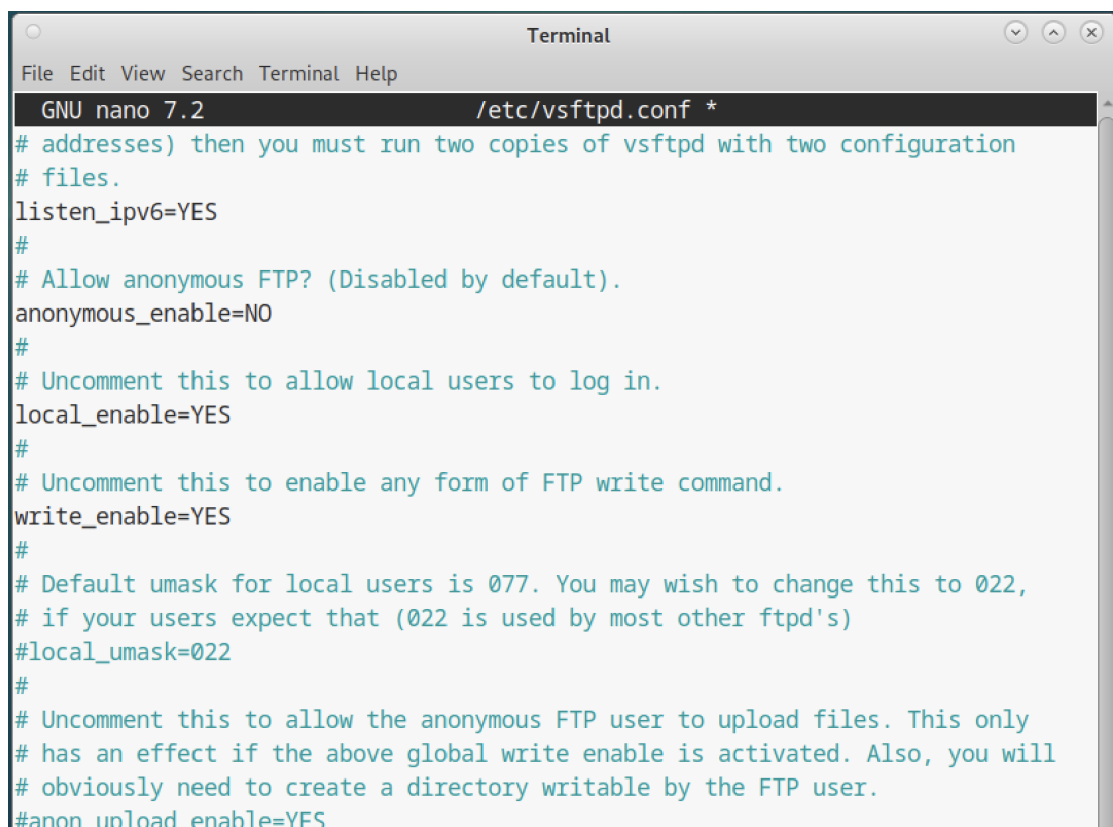
```
ufw allow ssh && ufw allow http && ufw allow https && ufw enable
```



A terminal window titled 'Terminal' with a menu bar (File, Edit, View, Search, Terminal, Help). The title bar shows 'GNU nano 7.2' and the file path '/etc/vsftpd.conf *'. The content of the file is as follows:

```
listen=NO
#
# This directive enables listening on IPv6 sockets. By default, listening
# on the IPv6 "any" address (:::) will accept connections from both IPv6
# and IPv4 clients. It is not necessary to listen on *both* IPv4 and IPv6
# sockets. If you want that (perhaps because you want to listen on specific
# addresses) then you must run two copies of vsftpd with two configuration
# files.
listen_ipv6=YES
#
# Allow anonymous FTP? (Disabled by default).
anonymous_enable=YES
#
# Uncomment this to allow local users to log in.
local_enable=YES
#
# Uncomment this to enable any form of FTP write command.
write_enable=YES
```

Configuración de vsftpd corregida



A terminal window titled 'Terminal' with a menu bar (File, Edit, View, Search, Terminal, Help). The title bar shows 'GNU nano 7.2' and the file path '/etc/vsftpd.conf *'. The content of the file is as follows:

```
# addresses) then you must run two copies of vsftpd with two configuration
# files.
listen_ipv6=YES
#
# Allow anonymous FTP? (Disabled by default).
anonymous_enable=NO
#
# Uncomment this to allow local users to log in.
local_enable=YES
#
# Uncomment this to enable any form of FTP write command.
write_enable=YES
#
# Default umask for local users is 077. You may wish to change this to 022,
# if your users expect that (022 is used by most other ftpd's)
#local_umask=022
#
# Uncomment this to allow the anonymous FTP user to upload files. This only
# has an effect if the above global write enable is activated. Also, you will
# obviously need to create a directory writable by the FTP user.
#anon_upload_enable=YES
```

Configuración de reglas UFW

```
Terminal
File Edit View Search Terminal Help
Rules updated
Rules updated (v6)
root@debian:/var/www/html# ufw allow http
Rules updated
Rules updated (v6)
root@debian:/var/www/html# ufw allow https
Rules updated
Rules updated (v6)
root@debian:/var/www/html# ufw enable
Firewall is active and enabled on system startup
root@debian:/var/www/html# ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN Anywhere
80/tcp ALLOW IN Anywhere
443 ALLOW IN Anywhere
22/tcp (v6) ALLOW IN Anywhere (v6)
80/tcp (v6) ALLOW IN Anywhere (v6)
443 (v6) ALLOW IN Anywhere (v6)

root@debian:/var/www/html#
```

Estado del firewall UFW activo

Estado: ✓ Corregida — FTP anónimo deshabilitado, firewall activo

VUL-005 - Information Disclosure - Apache

Campo	Detalle
Descripción	Apache exponía versión (2.4.62) y OS (Debian) en cabecera HTTP y página por defecto
Severidad	MEDIA
Impacto	Facilita reconocimiento y búsqueda de exploits específicos
Evidencia	curl -I revela Server: Apache/2.4.62 (Debian)

Corrección aplicada:

```
curl -I http://192.168.64.9
```

```
operador@debian-analista: ~  
operador@debian-analista:~$ curl -I http://192.168.64.9  
HTTP/1.1 200 OK  
Date: Wed, 11 Mar 2026 01:49:18 GMT  
Server: Apache/2.4.66 (Debian)  
Link: <http://localhost/index.php/wp-json/>; rel="https://api.w.org/"  
Content-Type: text/html; charset=UTF-8
```

Cabeceras HTTP antes de la corrección

ServerTokens Prod

ServerSignature Off

systemctl restart apache2

```
debian@debian:~$ curl -I http://192.168.64.9  
HTTP/1.1 200 OK  
Date: Wed, 11 Mar 2026 09:16:42 GMT  
Server: Apache  
Link: <http://localhost/index.php/wp-json/>; rel="https://api.w.org/"  
Content-Type: text/html; charset=UTF-8
```

Directivas de ocultamiento aplicadas en Apache

Estado: ✓ Corregida — Server: Apache sin versión expuesta

VUL-006 - Directorio web listable

Campo	Detalle
Descripción	Options Indexes activo: directorios sin index navegables públicamente
Severidad	MEDIA
Impacto	Acceso directo a archivos subidos, posible exfiltración sin autenticación
Evidencia	curl a /wp-content/uploads/ retorna listado de directorio

Corrección aplicada:

```
curl http://192.168.64.9/wp-content/uploads/
```

```

operator@debian-analista: ~
operator@debian-analista:~$ curl http://192.168.64.9/wp-content/uploads/
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html>
<head>
<title>Index of /wp-content/uploads</title>
</head>
<body>
<h1>Index of /wp-content/uploads</h1>
<table>
<tr><th valign="top"></th><th><a href="
"?C=N;0=D">Name</a></th><th><a href="?C=M;0=A">Last modified</a></th><th><a href="
"?C=S;0=A">Size</a></th><th><a href="?C=D;0=A">Description</a></th></tr>
<tr><th colspan="5"><hr></th></tr>
<tr><td valign="top"></td><td><a href=
"/wp-content/">Parent Directory</a></td><td>&nbsp;</td><td align="right"> -
</td><td>&nbsp;</td></tr>
<tr><td valign="top"></td><td><a href=
"2024/">2024/</a></td><td align="right">2024-10-08 16:49 </td><td align="right">
- </td><td>&nbsp;</td></tr>
<tr><td valign="top"></td><td><a href=
"2026/">2026/</a></td><td align="right">2026-03-09 18:52 </td><td align="right">
- </td><td>&nbsp;</td></tr>
<tr><th colspan="5"><hr></th></tr>

```

Listado de directorio expuesto antes de corrección

Options -Indexes +FollowSymLinks

```

Terminal
File Edit View Search Terminal Help
GNU nano 7.2      etc/apache2/apache2.conf *
Options Indexes FollowSymLinks
AllowOverride None
Require all granted
</Directory>

<Directory /usr/share>
AllowOverride None
Options Indexes FollowSymLinks
Require all granted
</Directory>

<Directory /var/www/>
Options -Indexes +FollowSymLinks
AllowOverride None
Require all granted
</Directory>

```

Directiva Options -Indexes aplicada

```
operator@debian-analista: ~  
operator@debian-analista:~$ curl http://192.168.64.9/wp-content/uploads/  
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/st  
rict.dtd">  
<html><head>  
<title>403 Forbidden</title>  
</head><body>  
<h1>Forbidden</h1>  
<p>You don't have permission to access this resource.</p>  
<hr>  
<address>Apache/2.4.66 (Debian) Server at 192.168.64.9 Port 80</address>  
</body></html>  
operator@debian-analista:~$
```

Verificación: acceso denegado (403 Forbidden)

Estado: ✓ Corregida — Acceso a directorios retorna 403 Forbidden

VUL-007 - XML-RPC habilitado (Brute Force / DLP)

Campo	Detalle
Descripción	Endpoint XML-RPC habilitado, permitiendo autenticación programática y system.multicall
Severidad	MEDIA
Impacto	Fuerza bruta amplificada, exfiltración de datos y evasión de rate limiting
Evidencia	curl a /xmlrpc.php confirma endpoint activo

Proceso de explotación

Paso 1 - Confirmación de acceso al endpoint:

```
curl -s http://192.168.64.9/xmlrpc.php
```

```
operator@debian-analista:~$ curl -s http://192.168.64.9/xmlrpc.php  
XML-RPC server accepts POST requests only.operator@debian-analista:~$ curl -s -X  
POST http://192.168.64.9/xmlcurl -s -X POST http://192.168.64.9/xmlrpc.php \  
-H "Content-Type: text/xml" \  
-d '<?xml version="1.0"?><methodCall><methodName>system.listMethods</methodName>
```

Endpoint XML-RPC accesible

Paso 2 - Enumeración de métodos (system.listMethods):

```
curl -s -X POST http://192.168.64.9/xmlrpc.php -H "Content-Type: text/xml" -d  
'<methodCall><methodName>system.listMethods</methodName></methodCall>'
```

```

operator@debian-analista: ~
operator@debian-analista:~$ curl -s -X POST http://192.168.64.9/xmlrpc.php \
-H "Content-Type: text/xml" \
-d '<?xml version="1.0"?><methodCall><methodName>system.listMethods</methodName><params></params></methodCall>'
<?xml version="1.0" encoding="UTF-8"?>
<methodResponse>
  <params>
    <param>
      <value>
        <array><data>
          <value><string>system.multicall</string></value>
          <value><string>system.listMethods</string></value>
          <value><string>system.getCapabilities</string></value>
          <value><string>demo.addTwoNumbers</string></value>
          <value><string>demo.sayHello</string></value>
          <value><string>pingback.extensions.getPingbacks</string></value>
          <value><string>pingback.ping</string></value>
          <value><string>mt.publishPost</string></value>
          <value><string>mt.getTrackbackPings</string></value>
          <value><string>mt.supportedTextFilters</string></value>
          <value><string>mt.supportedMethods</string></value>
          <value><string>mt.setPostCategories</string></value>
          <value><string>mt.getPostCategories</string></value>
          <value><string>mt.getRecentPostTitles</string></value>
          <value><string>mt.getCategoryList</string></value>
          <value><string>metaWeblog.getUsersBlogs</string></value>
          <value><string>metaWeblog.deletePost</string></value>
          <value><string>metaWeblog.newMediaObject</string></value>
        </data>
        </array>
      </value>
    </param>
  </params>
</methodResponse>

```

Métodos XML-RPC disponibles

Paso 3 - Explotación con wp.getUsersBlogs:

```
curl -s -X POST http://192.168.64.9/xmlrpc.php -d @/tmp/xmlrpc_attack.xml
```

```

operator@debian-analista:~$ curl -s -X POST http://192.168.64.9/xmlrpc.php \
-H "Content-Type: text/xml" \
-d @/tmp/multicall_attack.xml
<?xml version="1.0" encoding="UTF-8"?>
<methodResponse>
  <params>
    <param>
      <value>
        <array><data>
          <value><struct>
            <member><name>faultCode</name><value><int>403</int></value></member>
            <member><name>faultString</name><value><string>Incorrect username or password.
          </string></value></member>
          </struct></value>
          <value><struct>
            <member><name>faultCode</name><value><int>403</int></value></member>
            <member><name>faultString</name><value><string>Incorrect username or password.
          </string></value></member>
          </struct></value>
          <value><struct>
            <member><name>faultCode</name><value><int>403</int></value></member>
            <member><name>faultString</name><value><string>Incorrect username or password.
          </string></value></member>
        </data>
        </array>
      </value>
    </param>
  </params>
</methodResponse>

```

Intento de autenticación procesado vía XML-RPC

Paso 4 - system.multicall (fuerza bruta amplificada):

```
curl -s -X POST http://192.168.64.9/xmlrpc.php -d @/tmp/multicall_attack.xml
```

```

operador@debian-analista:~$ cat > /tmp/multicall_attack.xml << 'EOF'
<?xml version="1.0"?>
<methodCall>
  <methodName>system.multicall</methodName>
  <params><param><value><array><data>
    <value><struct>
      <member><name>methodName</name><value><string>wp.getUsersBlogs</string></v
alue></member>
      <member><name>params</name><value><array><data>
        <value><string>wordpress-user</string></value>
        <value><string>password1</string></value>
      </data></array></value></member>
    </struct></value>
    <value><struct>
      <member><name>methodName</name><value><string>wp.getUsersBlogs</string></v
alue></member>
      <member><name>params</name><value><array><data>
        <value><string>wordpress-user</string></value>
        <value><string>admin123</string></value>
      </data></array></value></member>
    </struct></value>
    <value><struct>
      <member><name>methodName</name><value><string>wp.getUsersBlogs</string></v

```

Múltiples intentos en una sola petición HTTP

Relación con DLP (Data Loss Prevention)

El endpoint XML-RPC compromete directamente los controles DLP porque: (1) permite extraer datos internos una vez obtenidas credenciales; (2) system.multicall elude los controles de rate limiting; (3) las requests XML-RPC son indistinguibles del tráfico HTTP legítimo en inspección superficial.

Corrección aplicada:

```

echo '<Files "xmlrpc.php"> Require all denied </Files>' | sudo tee -a /etc/apache2/apache2.conf
sudo systemctl restart apache2

```

```

debian@debian:~$ echo '
<Files "xmlrpc.php">
  Require all denied
</Files>' | sudo tee -a /etc/apache2/apache2.conf
[sudo] password for debian:

<Files "xmlrpc.php">
  Require all denied
</Files>

```

Regla de bloqueo añadida en apache2.conf

```

    Require all denied
  </Files>
debian@debian:~$ sudo systemctl restart apache2
debian@debian:~$

```


Reinicio de Apache aplicado

```
debian@debian:~$ curl -s -o /dev/null -w 'HTTP Status: %{http_code}' http://192.168.64.9/xmlrpc.php
HTTP Status: 403debian@debian:~$
```

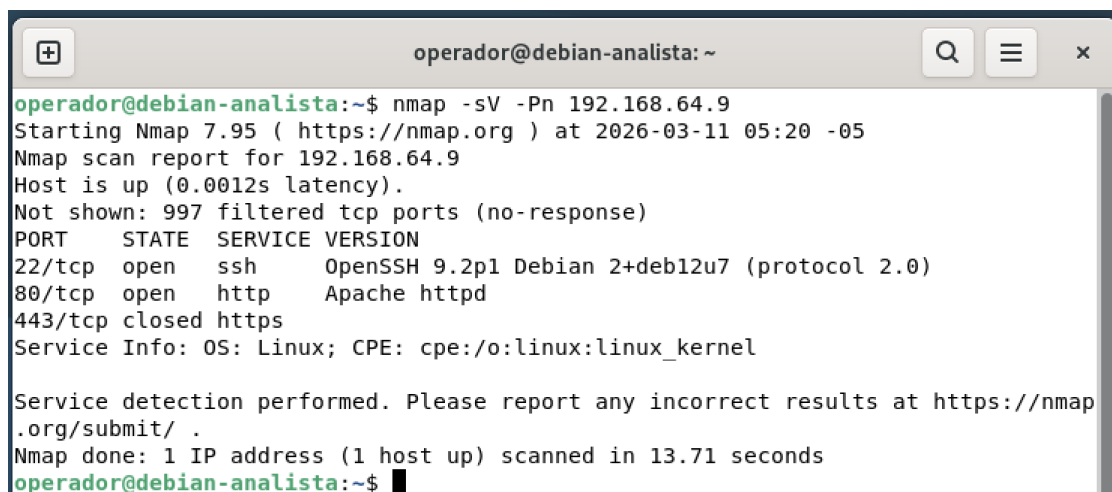
Verificación: xmlrpc.php retorna 403 Forbidden

Estado: ✓ Corregida — curl a xmlrpc.php retorna HTTP 403 Forbidden

7. Validación Post-hardening

Tras aplicar todas las correcciones, se realizó un escaneo de validación para confirmar el estado final del servidor desde la perspectiva de un actor externo.

```
nmap -sV -Pn 192.168.64.9
```



```
operador@debian-analista:~$ nmap -sV -Pn 192.168.64.9
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 05:20 -05
Nmap scan report for 192.168.64.9
Host is up (0.0012s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
80/tcp    open  http     Apache httpd
443/tcp   closed https
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.71 seconds
operador@debian-analista:~$
```

Escaneo Nmap post-hardening

Puerto	Estado	Servicio	Observación
21/tcp	filtered	ftp	Bloqueado por UFW
22/tcp	open	ssh	Solo autenticación por clave pública
80/tcp	open	http	Apache sin versión expuesta
443/tcp	open	https	Habilitado
FTP anónimo	—	—	Deshabilitado
XML-RPC	—	—	HTTP 403 Forbidden
Dir. listable	—	—	Options -Indexes activo

8. Recomendaciones

#	Recomendación	Prioridad	Estado	Observación
1	Implementar Wazuh SIEM/EDR	ALTA	Pendiente	Monitoreo continuo y correlación de logs
2	Configurar HTTPS con certificado	ALTA	Pendiente	Cifrado de tráfico web
3	Actualizar OS y servicios	ALTA	Pendiente	Parches de seguridad para CVEs
4	Implementar WAF	MEDIA	Pendiente	Protección adicional para WordPress
5	Configurar backups automáticos	MEDIA	Pendiente	Respaldo periódico de datos
6	Implementar fail2ban	MEDIA	Pendiente	Protección contra fuerza bruta
7	Auditoría periódica	MEDIA	Pendiente	Evaluaciones trimestrales
8	Capacitación en seguridad	BAJA	Pendiente	Formación del equipo técnico

Consideraciones DLP (Data Loss Prevention)

Durante la evaluación se identificaron múltiples vectores con implicaciones directas en la prevención de pérdida de datos:

- XML-RPC (VUL-007): permitía exfiltración masiva de datos WordPress mediante autenticación programática no controlada. Corregido bloqueando el endpoint a nivel Apache.
- Credenciales en texto plano (VUL-001 / VUL-003): las credenciales de BD eran accesibles en wp-config.php con permisos 777. Un proceso comprometido podía extraer hashes sin rastro.
- Directorio web listable (VUL-006): permitía listar y descargar todos los archivos subidos al servidor sin autenticación.
- Recomendación activa: implementar Wazuh SIEM/EDR para monitoreo continuo de transferencias de datos, alertas por acceso masivo y correlación de logs entre Apache, SSH y MariaDB.

9. Conclusión

La evaluación identificó siete vulnerabilidades activas en el servidor web de 4Geeks Academy mediante dos ciclos de análisis. Las tres de severidad ALTA — credenciales débiles en base de datos, autenticación SSH insegura y permisos incorrectos en wp-config.php — podrían encadenarse para otorgar acceso completo al sistema. Las cuatro de severidad MEDIA ampliaban la superficie de ataque.

Todas las vulnerabilidades fueron completamente corregidas y verificadas. El servidor opera al cierre de este informe con una postura de seguridad significativamente mejorada. El análisis profundo de Fase 2 (nikto, wpscan, nmap --script vuln) fue determinante para identificar VUL-007, vector con implicaciones directas en DLP que no era visible en el reconocimiento inicial.

Métricas Finales

Métrica	Valor
Vulnerabilidades identificadas	7
Severidad ALTA	3
Severidad MEDIA	4
Corregidas	7 (100%)
Ciclos de análisis	2 (Reconocimiento + Análisis Profundo)
Estado del servidor	Hardening aplicado — superficie reducida

Jose Muñoz A.

Analista de Seguridad - NexusTrace S.A.S

Marzo 2026